SECURITY REQUIREMENTS DOCUMENT

Online Quiz Management System

1. Introduction

The Online Quiz Management System is a web-based application that allows users to access quizzes, attempt questions, and view quiz results. Security is important to protect user accounts, quiz questions, answers, and student results from unauthorized access.

This document describes the security requirements that should be followed while developing and maintaining the system.

2. Objectives

The main objectives of the security requirements are:

- To protect user accounts and personal information.
- To prevent unauthorized access to quizzes and results.
- To ensure that only authorized users can manage quizzes.
- To protect passwords and other sensitive information.
- To maintain the confidentiality, integrity, and availability of system data.

3. Scope

These security requirements apply to the main components of the Online Quiz Management System, including user authentication, quiz management, question storage, quiz attempts, result management, and database access.

The requirements should be adjusted according to the features and user roles implemented in the actual project.

4. Security Requirements

SR-01: User Authentication

The system shall require users to log in before accessing features that require authentication.

SR-02: Password Security

The system shall store passwords securely using an appropriate password-hashing algorithm. Passwords shall not be stored in plain text.

SR-03: Role-Based Access Control

The system shall restrict access to features according to user roles, such as student, instructor, or administrator, wherever those roles are supported.

SR-04: Quiz Management Security

Only authorized users shall be allowed to create, edit, publish, or delete quizzes and questions.

SR-05: Quiz Result Protection

Students shall be allowed to view their own results. Access to other students' results shall be restricted unless explicitly permitted by an authorized role.

SR-06: Input Validation

The system shall validate user inputs before processing them to reduce the risk of invalid data, injection attacks, and unexpected application behavior.

SR-07: Session Management

The system shall manage user sessions securely. Users shall be able to log out, and inactive sessions should expire according to the application's security settings.

SR-08: Data Confidentiality

Personal information, login credentials, quiz answers, and results shall be accessible only to authorized users and system components.

SR-09: Secure Communication

When deployed, the application shall use HTTPS to protect information transmitted between the user's browser and the server.

SR-10: Error Handling

The system shall display user-friendly error messages without revealing database details, internal system information, passwords, or secret tokens.

SR-11: Protection of Configuration and Secrets

Database credentials, API keys, and secret tokens shall not be exposed in client-side code or committed to the GitHub repository.

SR-12: Login Abuse Prevention

The system should limit repeated unsuccessful login attempts and use suitable protections against automated login attacks.

SR-13: Database Security

Database access shall be restricted to authorized application components and users. Appropriate permissions and secure database queries shall be used.

SR-14: Security Logging

The system should record important security events, such as repeated failed login attempts and administrative changes, without recording passwords or secret tokens.

SR-15: Backup and Recovery

Important application data should be backed up securely, and recovery procedures should be tested where applicable.

5. Security Principles

The system should follow these security principles:

Confidentiality: Only authorized users should be able to access protected information.

Integrity: Quiz questions, answers, user information, and results should not be changed by unauthorized users.

Availability: The system should remain accessible to legitimate users when required.

Authentication: The system should verify a user's identity before granting access to protected features.

Authorization: The system should determine which features and data an authenticated user is permitted to access.

6. Security Testing Requirements

The following checks should be performed to verify the system's security:

1. Attempt to access protected pages without logging in.
2. Verify that users cannot access features outside their assigned permissions.
3. Check whether a student can access another student's results by changing an identifier in a URL or request.
4. Submit invalid inputs and verify that the system handles them safely.
5. Verify that passwords and secret credentials are not stored or displayed in plain text.
6. Check that logging out prevents further use of the invalidated session.
7. Verify that database credentials and secret keys are not exposed in the repository.
8. Check that the application uses HTTPS in its deployed environment.

7. Expected Outcomes

After implementing and testing the applicable security requirements:

- Unauthorized access to protected features should be prevented.
- User passwords and sensitive information should be protected.
- Quiz questions and results should be accessible only to permitted users.
- Invalid input should be handled safely.
- Sensitive configuration information should remain confidential.
- The system should provide a safer and more reliable experience for users.

8. Conclusion

Security is an important part of the Online Quiz Management System because the application handles user accounts, quiz content, and assessment results. Implementing suitable authentication, authorization, input validation, secure data handling, and security testing can reduce common security risks.

The development team should verify each requirement against the actual implementation and record whether it is implemented, partially implemented, or pending.

Document: Security Requirements Document
Project: Online Quiz Management System
Version: 1.0